

Security Architecture

Identity Verification

Authentication establishes the identity associated with an API request. Access tokens must be validated before protected resources are accessed. Invalid or expired credentials must not reach resource-level authorization logic as if they represented a valid identity.

Authorization

Authorization determines whether an authenticated user may perform an operation against a resource. A valid identity alone does not grant access to every document, chat, message, or vector belonging to another user.

Tenant Isolation

Tenant isolation requires every document retrieval path to preserve the authenticated user's ownership boundary. Document identifiers are not authorization credentials. A caller who knows another user's document ID must still be unable to retrieve that document.

Document Ownership

A document is owned by a user and associated with a chat. Ownership validation should verify the document user relationship and the owning chat's user relationship. Both relationships are relevant because the chat is part of the document ownership chain.

IDOR Protection

Insecure direct object reference, or IDOR, occurs when an attacker can substitute another object's identifier and receive that object without an authorization check. Document IDs, chat IDs, and message IDs must therefore always be resolved within the authenticated ownership boundary.

Session Access

Session state must not be treated as proof that a caller owns an arbitrary resource identifier. Authentication provides the principal identity, while authorization checks determine whether that principal may access the requested resource.

Audit Logging

Security-relevant events should contain sufficient structured context to support investigation. Request IDs, user identifiers where appropriate, resource IDs, operation names, and failure classifications may be recorded without storing secrets or access tokens.

Least Privilege

Services and database operations should use the minimum privileges necessary for their function. Evaluation workloads should use an isolated test database rather than credentials capable of modifying production data.

Data Boundary

Vector search is part of the protected document-data boundary. Candidate generation must respect ownership constraints rather than retrieving a broad set of cross-tenant candidates and filtering them afterward.